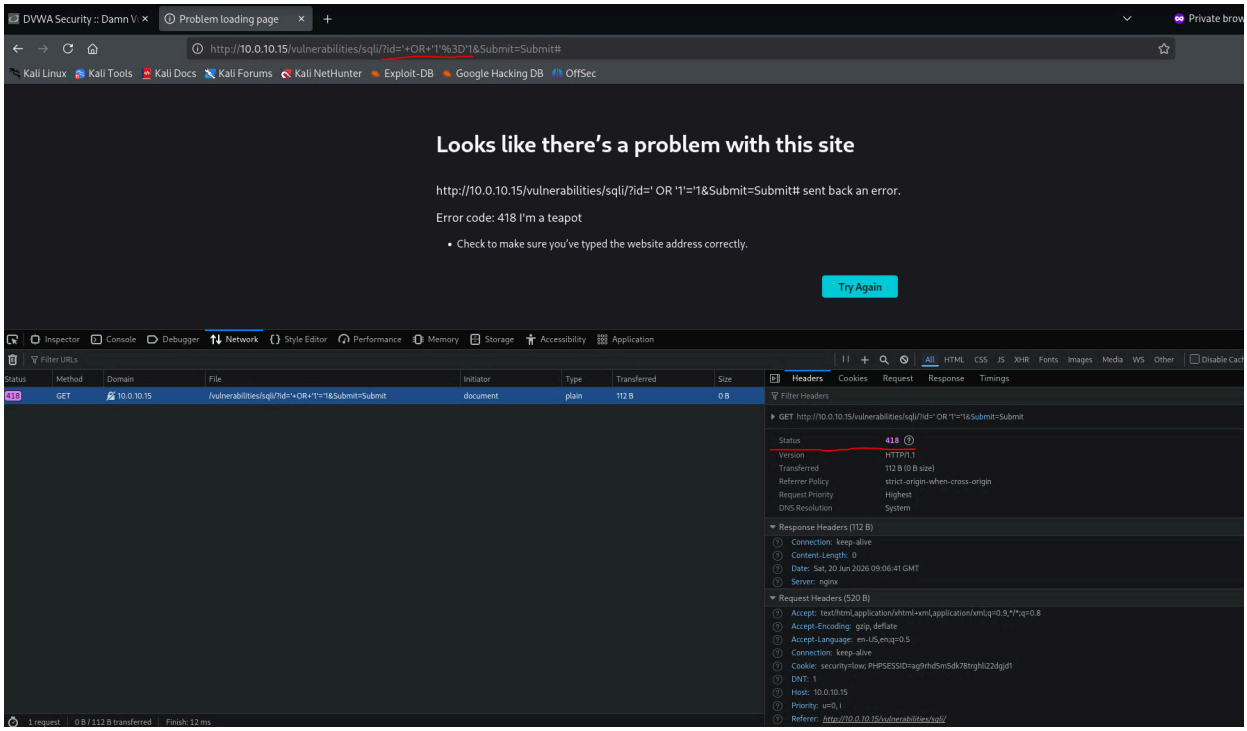
Web application firewall для защиты веб-приложений - Практическая работа

Задание 1. Работа с правилами WAF на примере ModSecurity



- SQL-инъекция прошла через WAF - в адресной строке виден пейлоад id='+OR+'1'%3D'1
- Код ответа изменился с 403 на 418 - в таблице Network видно статус 418 (I'm a teapot) для запроса к 10.0.10.15/vulnerabilities/sqli/
- Браузер показывает ошибку 418 - "Error code: 418 I'm a teapot"

Задание 2. Написание собственного правила для ModSecurity для защиты от SQL инъекции

Вредоносный код для инъекции (стандартная SQLi):

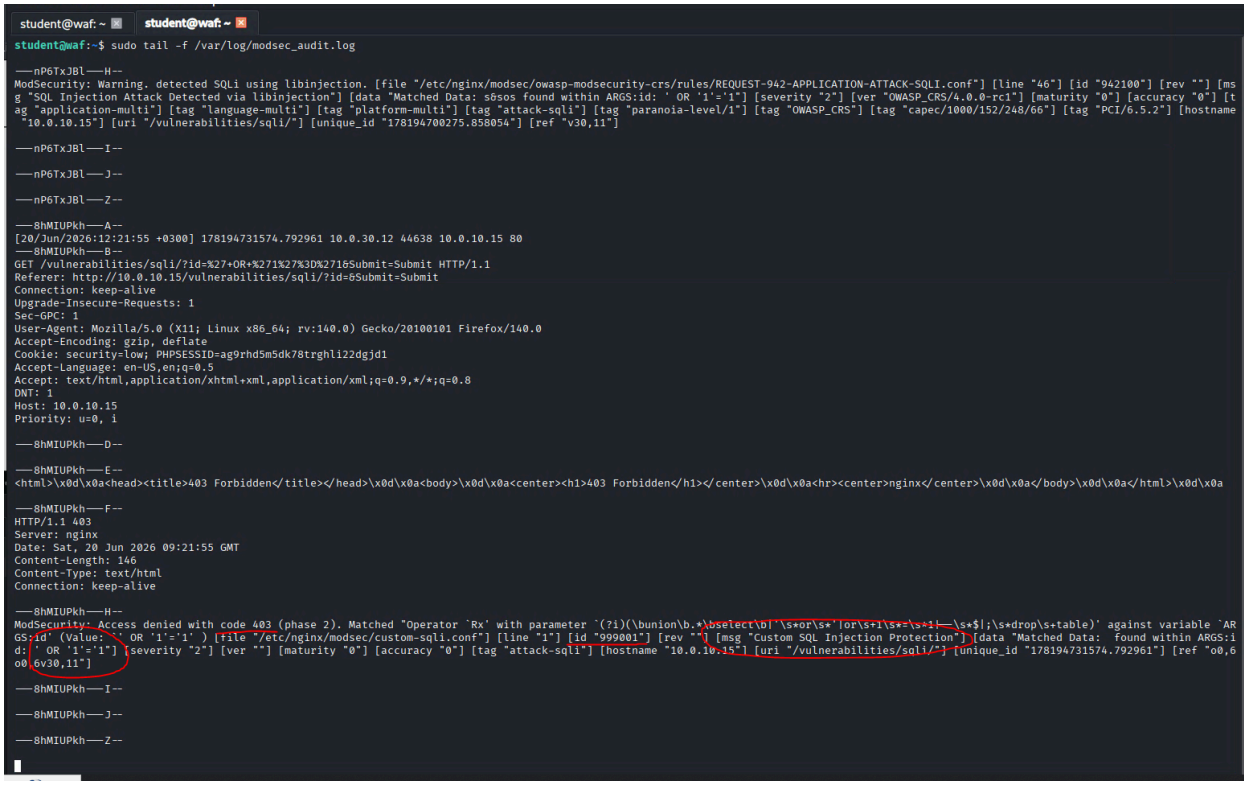
```
' OR '1'='1
```

Код нового кастомного правила:

```
SecRule ARGS "@rx (?i)(\bunion\b.*\bselect\b|'\s*or\s*'|or\s+1\s*=\s*1|--\s*$|;\s*drop\s+table)" \
   "id:999001,\
   phase:2,\
   deny,\
   status:403,\
   msg:'Custom SQL Injection Protection',\
   log,\
   logdata:'Matched Data: %{TX.0} found within %{MATCHED_VAR_NAME}:
%{MATCHED_VAR}',\
   tag:'attack-sqli',\
   severity:'CRITICAL'"
```

Что делает это правило:

- SecRule ARGS - проверяет все параметры запроса (GET и POST)
- @rx - оператор регулярных выражений
- (?i) - регистронезависимый поиск
- Шаблон ищет:
- union ... select - UNION-инъекция
- ' or ' - инъекция через одинарные кавычки (пейлоад ' OR '1'='1)
- or 1=1 - булева инъекция
- -- в конце - SQL-комментарий
- ; drop table - попытка удалить таблицу



id "999001" - ID кастомного правила

- msg "Custom SQL Injection Protection" - кастомное сообщение
- Файл: /etc/nginx/modsec/custom-sqli.conf

Атака заблокирована:

- Виден код ответа 403 Forbidden (в секции F--)
- ModSecurity отклонил запрос: Access denied with code 403 (phase 2)

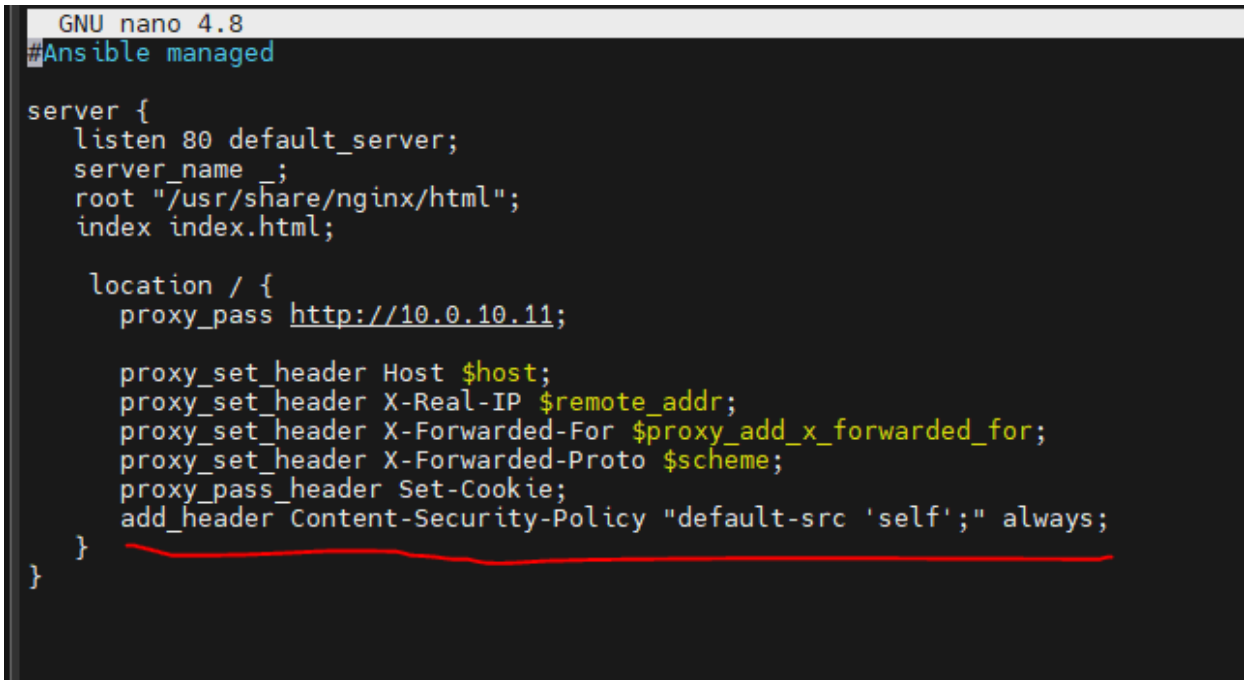
Пейлоад атаки зафиксирован:

- ' OR '1'='1 - виден в логе в поле ARGS:id

Задание 3. Реализация CSP в приложении

Код конфигурации Nginx:

Строка отвечает за то, чтобы исполнялся код только с этого же домена:



Подтверждаем изменения:

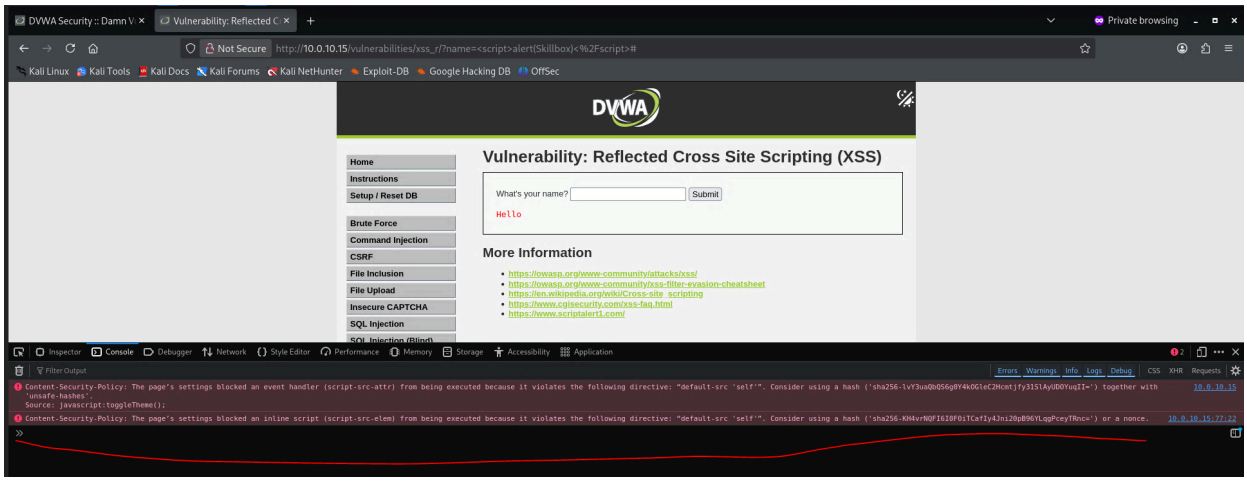
```
student@waf:~$ sudo nginx -t
nginx: the configuration file /etc/nginx/nginx.conf syntax is ok
nginx: configuration file /etc/nginx/nginx.conf test is successful
student@waf:~$ sudo systemctl reload nginx
student@waf:~$ curl -I http://10.0.10.15
HTTP/1.1 302 Found
Server: nginx
Date: Sat, 20 Jun 2026 09:30:55 GMT
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
X-Powered-By: PHP/5.4.16
Set-Cookie: security=impossible; path=/; httponly
Set-Cookie: PHPSESSID=t92klu0r06rh7u7aj58n3d4810; path=/
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate, post-check=0, pre-check=0
Pragma: no-cache
Set-Cookie: PHPSESSID=u6a14cpeuffamqci7q970hhul7; path=/
Location: login.php
Content-Security-Policy: default-src 'self';

student@waf:~$
```

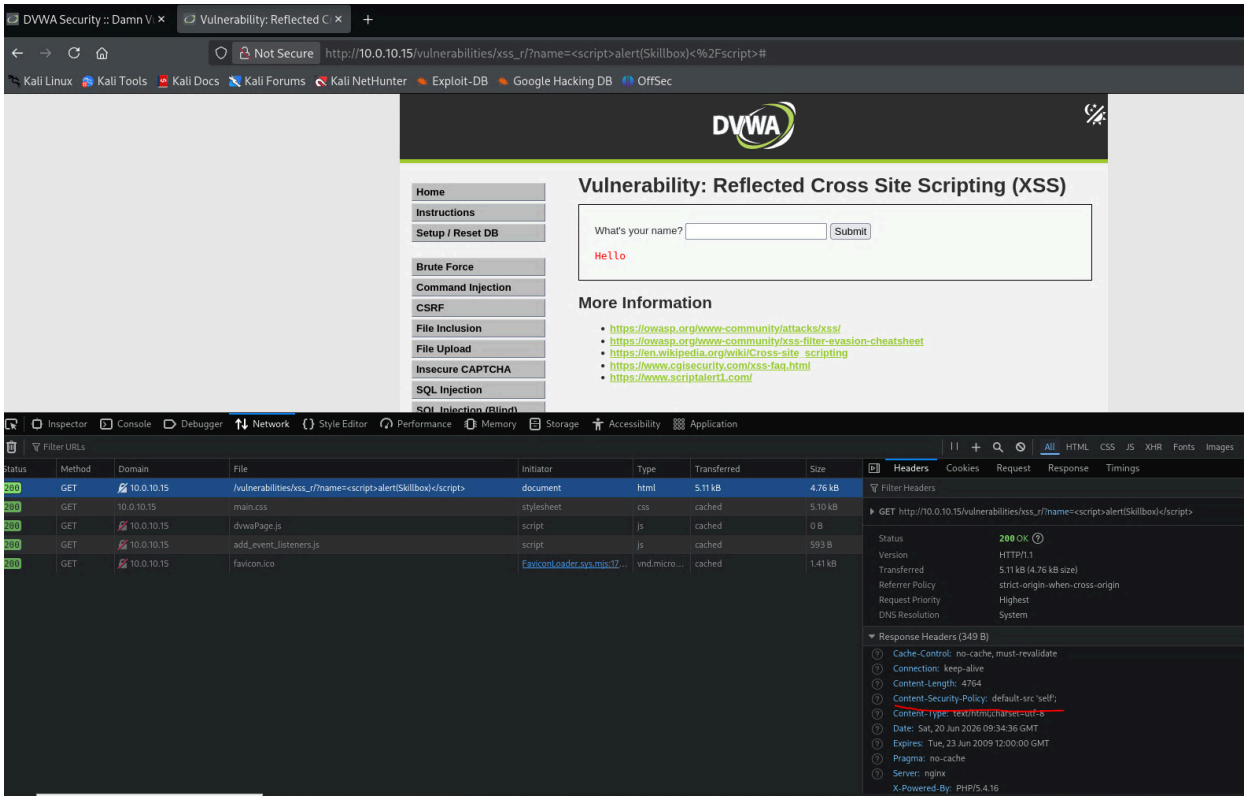
В консоли разработчика видны ошибки CSP:

Content-Security-Policy: The page's settings blocked an event handler (script-src-attr) from being executed because it violates the following directive: "default-src 'self'"

Content-Security-Policy: The page's settings blocked an inline script (script-src-elem) from being executed because it violates the following directive: "default-src 'self'"



Скрипт не выполнился: вместо alert(Skillbox) страница просто отобразила текст "Hello" – CSP успешно заблокировал выполнение вредоносного JavaScript.


DVWA Security :: Damn V
Vulnerability: Reflected C
Not Secure
http://10.0.10.15/vulnerabilities/xss_r/?name=<script>alert(Skillbox)<%2Fscript>#
Kali Linux
Kali Tools
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec
DVWA
Home
Instructions
Setup / Reset DB
Brute Force
Command Injection
CSRF
File Inclusion
File Upload
Insecure CAPTCHA
SQL Injection
Vulnerability: Reflected Cross Site Scripting (XSS)
What's your name?
Submit
Hello
More Information
https://owasp.org/www-community/attacks/xss/
https://owasp.org/www-community/xss-filter-evasion-cheatsheet
https://en.wikipedia.org/wiki/Cross-site_scripting
https://www.cgisecurity.com/xss-faq.html
https://www.scriptalert1.com/
Inspector
Console
Debugger
Network
Style Editor
Performance
Memory
Storage
Accessibility
Application
Filter URLs
Status
Method
Domain
File
Initiator
Type
Transferred
Size
200 GET 10.0.10.15 /vulnerabilities/xss_r/?name=<script>alert(Skillbox)</script> document html 5.11 kB 4.76 kB
200 GET 10.0.10.15 main.css stylesheet css cached 5.10 kB
200 GET 10.0.10.15 dvwaPage.js script js cached 0 B
200 GET 10.0.10.15 add_event_listeners.js script js cached 593 B
200 GET 10.0.10.15 favicon.ico FaviconLoader.sys.mjs:17... vnd.micro... cached 1.41 kB
Headers
Cookies
Request
Response
Timings
GET http://10.0.10.15/vulnerabilities/xss_r/?name=<script>alert(Skillbox)</script>
Status 200 OK
Version HTTP/1.1
Transferred 5.11 kB (4.76 kB size)
Referrer Policy strict-origin-when-cross-origin
Request Priority Highest
DNS Resolution System
Response Headers (349 B)
Cache-Control: no-cache, must-revalidate
Connection: keep-alive
Content-Length: 4764
Content-Security-Policy: default-src 'self';
Content-Type: text/html;charset=utf-8
Date: Sat, 20 Jun 2026 09:34:36 GMT
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Pragma: no-cache
Server: nginx
X-Powered-By: PHP/5.4.16